

Infographic for CMT 446

Module 2: IT Risk Management

(10-Slide Visual Summary)

Slide 1: Module 2 Title & Intro

CMT 446

IT Risk Management
Managing Uncertainty,
Ensuring Value

Instructor: Dr. Stanley Mwangi Chege
[University Name]



Slide 2: The Risk Equation

The Formula

$$\text{Threat (Hacker)} \times \text{Vulnerability (Unpatched Server)} \times \text{Asset Value (Database)} = \text{Risk}$$

Slide 3: Risk Management Lifecycle



Slide 4: Quantitative Risk Assessment

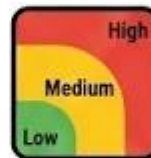
The Math

$$\text{SLE (Single Loss)} \times \text{ARO (Frequency)} = \text{ALE (Annual Loss)}$$

Slide 4: Qualitative Risk Assessment



Slide 5: Qualitative Risk Assessment



Subjective Analysis

Best for intangible assets like Reputation.

Slide 6: Internal Control Frameworks – COSO



Slide 6: Internal Control Frameworks – ~



Slide 7: Internal Control Frameworks – COBIT 2019



Aligns IT with Enterprise strategy.

Slide 8: Types of Internal Controls



Preventive:
Stops incident



Detective:
Alerts incident



Corrective:
Fixes damage

Slide 9: Standard Mapping – ISO/IEC 27001:2022



- 5.7 Threat Intelligence
- 8.8 Tech Vulnerability Mgmt
- 8.28 Secure Coding

Slide 10: Risk Treatment Strategies

Mitigate
(Control)

Accept
(Live with it)



Transfer
(Insurance)

Avoid
(Stop activity)

COURSE 2: CMT 446 – IT Risk Management & Internal Controls

Module 2: Risk Assessment & Control Frameworks (Expanded)

Slide 1: Module Overview – Why Risk Management Exists

Reality Check

- Zero risk does not exist
- Security is about **risk-informed decisions**

Key Idea

Risk management is a **business process**, not an IT checklist

Audit Role

- Validate:
 - Risks are identified
 - Controls are appropriate
 - Residual risk is acceptable
-

Slide 2: The Risk Equation (Fully Explained)

Risk Exists When:

- A valuable **asset**
- Is exposed to a **threat**
- Through a **vulnerability**

Example

- Asset: Customer database
- Threat: Hacker
- Vulnerability: Unpatched web server

No vulnerability = No risk, even if threat exists

Slide 3: Risk Management Lifecycle (In Practice)

1. Identify

- Asset register
- Threat catalog

2. Assess

- Likelihood × Impact

3. Treat

- Controls selected

4. Monitor

- Continuous reassessment

Why Monitoring Matters

- Threats evolve faster than policies
-

Slide 4: Quantitative Risk Assessment (Numbers Matter)

Formulas

- $SLE = \text{Asset Value} \times \text{Exposure Factor}$
- $ALE = SLE \times ARO$

Example

- Asset value: \$100,000
- Exposure: 30%
- ARO: 1 per year
- $ALE = \$30,000$

Decision Logic

- Spending \$10k on controls makes sense
 - Spending \$100k does not
-

Slide 5: Qualitative Risk Assessment

Why Use It

- Not everything has a price:
 - Reputation
 - Trust
 - Regulatory penalties

Tools

- Risk heat maps
- H/M/L scoring

Strength

- Strategic decision-making
 - Board-level communication
-

Slide 6: COSO Internal Control Framework

COSO

Focus

- Enterprise-wide risk management

Five Components

1. Control Environment
2. Risk Assessment
3. Control Activities
4. Information & Communication
5. Monitoring

Used By

- Boards
 - Auditors
 - Regulators
-

Slide 7: COBIT 2019 – IT Governance Lens

COBIT 2019

Purpose

- Align IT with business value

Key Question

Is IT enabling strategy or just consuming budget?

Audit Value

- Evaluates:
 - Effectiveness
 - Efficiency
 - Alignment
-

Slide 8: Types of Internal Controls (Expanded)

Type	Purpose	Example
Preventive	Stop incident	MFA
Detective	Detect incident	SIEM
Corrective	Recover	Backups
Directive	Guide behavior	Policies

Best Practice

- Layer all four types

Slide 9: Standard Mapping – ISO/IEC 27001

Key Controls

- 5.7 – Threat Intelligence
- 8.8 – Vulnerability Management
- 8.28 – Secure Development

Audit Insight

- Risk management must be **documented and repeatable**

Slide 10: Risk Treatment Strategies (Decision Logic)

- **Mitigate:** Reduce risk
- **Transfer:** Insurance, outsourcing
- **Accept:** Low impact / cost
- **Avoid:** Stop activity

Critical Exam Insight

Acceptance must be **approved**, not accidental

CMT 446 – IT Risk Management & Internal Controls

Module 2 Quiz

Questions

Q1. In IT risk management, risk exists only when:

- A. A threat is present
- B. A vulnerability is present

- C. An asset, threat, and vulnerability coexist
- D. Controls are missing

Q2. Which component of risk represents the potential cause of harm?

- A. Asset
- B. Threat
- C. Vulnerability
- D. Control

Q3. What is the main purpose of risk assessment?

- A. Eliminating all risks
- B. Determining acceptable risk levels
- C. Enforcing compliance
- D. Identifying security incidents

Q4. Which formula correctly defines Annualized Loss Expectancy (ALE)?

- A. Asset Value $\times$ Exposure Factor
- B. SLE $\div$ ARO
- C. SLE $\times$ ARO
- D. Impact $\times$ Likelihood

Q5. Why is qualitative risk assessment useful?

- A. It provides exact financial values
- B. It replaces quantitative analysis
- C. It helps assess intangible risks
- D. It eliminates subjectivity

Q6. Which COSO component emphasizes “tone at the top”?

- A. Risk Assessment
- B. Control Environment
- C. Monitoring Activities
- D. Control Activities

Q7. COBIT 2019 primarily focuses on:

- A. Financial reporting accuracy
- B. Enterprise ethics
- C. IT governance and value delivery
- D. Physical security

Q8. An intrusion detection system (IDS) is an example of which control type?

- A. Preventive
- B. Detective
- C. Corrective
- D. Directive

Q9. Accepting a risk means:

- A. Ignoring it
- B. Eliminating it
- C. Transferring it
- D. Acknowledging and tolerating it

Q10. Which risk treatment strategy involves purchasing cyber insurance?

- A. Avoid
 - B. Accept
 - C. Mitigate
 - D. Transfer
-

Answers

- 1. **C**
- 2. **B**
- 3. **B**
- 4. **C**
- 5. **C**
- 6. **B**
- 7. **C**
- 8. **B**
- 9. **D**
- 10. **D**